

Comment Template for: NIST SP 800-157r1 (Final Public Draft)

Please submit responses to piv_comments@nist.gov by January 10, 2025

Organization:	RSA
Name of Submitter/POC:	
Email Address of Submitter/POC:	

Comment #	Section	Page #	Line #	Comment (Include rationale for comment)	Suggested Change
1	1.2/1.3	2, 16		Sections 1.2 and 3.2.1 refers to WebAuthn as a suitable authentication process, but doesn't explicitly mention FIDO2 authenticators, which uses/relies on Webauthn.	Would be good to explicitly mentioned that FIDO2 certified authenticators can be used as authenticators for Derived PIV, even if this is depending on further definition in other NIST documentation, such as 800-63B
2	C.2	29		Section C.2 gives the example of using a mobile device as an DPIV authenticator... while the example given seems to follow what FIDO 2 authentication/passkey mechanism is about, it's fairly generic, and doesn't explicitly mention FIDO 2 authentication, which could be confusing, and led to questions from readers about 'is FIDO 2 authentication with a mobile device accepted or not?' FIDO 2 authentication with mobile devices becomes more and more common these days... Synced Passkeys are supported natively from iOS 17 and Android 14, and more and more IAM vendors are implementing specific passkey/FIDO 2 authentication support in their own authenticators app, such as RSA, Microsoft, HYPR, etc, etc....	Make the example more explicit mentioning how to use FIDO 2 authentication with a mobile device, even if this is depending on further definition in other NIST documentaion, such as 800-63B